



UNIVERSIDAD POLITECNICA DE SAN LUIS POTOSI

Act15: SET

Carrera: ITI

Asignatura: CNO V Seguridad Informática

Salazar Hernández Pablo de Jesús - 171580

Cavazos Zacarías Rodolfo – 178823

Nieto Diaz de Leon Jair de Jesus – 171676

Gutiérrez Hernández Rodolfo – 179598

Morquecho Medina Eduardo Gabriel – 175805

Bustamante Rocha Cristopher Leonardo - 173754

Mtro. Servando López Contreras

27/04/2026

Introducción

La ingeniería social es una de las técnicas de ataque más prevalentes en el panorama actual de la ciberseguridad. A diferencia de los ataques puramente técnicos, la ingeniería social explota factores humanos como la confianza, la urgencia y la autoridad para inducir a las víctimas a revelar información sensible o realizar acciones comprometedoras. Según el informe Verizon DBIR 2023, más del 74% de todas las brechas de seguridad involucran el factor humano.

El proceso de creación del ataque de phishing mediante el **Social-Engineer Toolkit (SET)** comienza con la fase de **Armamento (Weaponization)**. En esta etapa, el atacante no busca vulnerar el software, sino la percepción del usuario. Utilizando el módulo *Website Attack Vectors* y la función *Site Cloner*, SET realiza una copia exacta del código HTML y CSS de un sitio legítimo. Esta técnica es altamente efectiva porque el servidor del atacante sirve archivos reales del sitio suplantado, lo que hace que la interfaz sea visualmente idéntica a la original.

Posteriormente, se modifica la lógica del formulario mediante la alteración del atributo `action` en el código fuente. Esto permite que, al momento de que la víctima ingrese sus credenciales, los datos no sean enviados al servidor auténtico, sino redirigidos hacia un **Listener** controlado por el atacante (en nuestro caso, configurado en el puerto 8000). Este flujo de trabajo demuestra cómo herramientas automatizadas pueden convertir un servidor de archivos común en un vector de recolección de datos masivo en cuestión de minutos.

En este contexto, la presente práctica tiene como objetivo explorar el funcionamiento del Social-Engineer Toolkit (SET), una suite de código abierto desarrollada por TrustedSec que automatiza y facilita la creación de ataques de ingeniería social con fines educativos y de auditoría. Concretamente, se ejecutó un ataque controlado de spear-phishing por correo electrónico desde un servidor SMTP propio hacia una dirección de prueba previamente configurada, sin involucrar a terceros.

1. Objetivo

Demostrar la ejecución de un ataque de phishing mediante el envío masivo de correos electrónicos (*Mass Mailer Attack*) utilizando la herramienta **Social-Engineer Toolkit (SET)**, superando las restricciones actuales de seguridad de los proveedores de correo comerciales, mediante la integración de un servidor **SMTP Relay**.

2. Infraestructura y Herramientas

- **Sistema Operativo Atacante:** Kali Linux (Entorno Virtualizado).
- **Herramienta de Auditoría:** SEToolkit v8.0.3.
- **Servidor SMTP:** Brevo (Servicio de Relay).
- **Protocolo de Seguridad:** STARTTLS en el puerto 587.
- **Objetivo de Prueba:** Cuenta de correo personal en Gmail.

3. Fase 1: Configuración del Servidor de Correo (SMTP Relay)

Debido a que los proveedores modernos han eliminado el "Acceso de aplicaciones poco seguras", se optó por configurar un servidor de retransmisión profesional para garantizar la entregabilidad del mensaje.

1. **Registro en Brevo:** Se creó una cuenta para gestionar el envío de correos transaccionales.
2. **Generación de Credenciales:**
 - Se accedió al panel de **SMTP y API**.
 - Se obtuvo el servidor: smtp-relay.brevo.com y el puerto 587.
 - Se generó una **Clave SMTP** única para la autenticación, la cual actúa como una capa de seguridad para permitir que la herramienta externa (SEToolkit) realice el envío.

SMTP y API

SMTP Claves API y MCP

Tu configuración SMTP

Servidor SMTP smtp-relay.brevo.com
Puerto 587
Iniciar sesión a97304[REDACTED]@smtp-brevo.com

Tus claves SMTP

Q Buscar tus claves SMTP

Valor de clave SMTP	Nombre de clave SMTP	Estado
☐ *****ECjMU0	seet	Activa

3. **Validación de Remitente:** Se verificó la dirección de correo origen en la sección de "Remitentes y Dominios" para evitar el rechazo inmediato por parte de los filtros SPF/DKIM de Google.

Finaty Customers <[REDACTED]@gmail.com> ● Verificado

Dirección IP	Firma DKIM
IP compartida ?	Predeterminado

4. Fase 2: Configuración del Ataque en SEToolkit

Se procedió a la configuración del vector de ataque dentro de la terminal de Kali Linux siguiendo la ruta:

1. **Menu:** Social-Engineering Attacks > Mass Mailer Attack.
2. **Opción:** E-Mail Attack Single Email Address.

3. **Template:** One Time Use Email Template



```
Session Actions Edit View Help
It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

Unable to check for new version of SET (is your network up?)

Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 5

Social Engineer Toolkit Mass E-Mailer

There are two options on the mass e-mailer, the first would
be to send an email to one individual person. The second option
will allow you to import a list and send it to as many people as
you want within that list.

What do you want to do:

1. E-Mail Attack Single Email Address
2. E-Mail Attack Mass Mailer

99. Return to main menu.

set:mailer>1
```



```
Shell No. 1
Session Actions Edit View Help
ine of the body: Next line of the body: Next line of the body: Next line of t
he body: Next line of the body: Next line of the body: Next line of the body:
Next line of the body: Next line of the body: Next line of the body: Next li
ne of the body: Next line of the body: Next line of the body: Next line of th
e body: Next line of the body: Next line of the body: Next line of the body:
Next line of the body: Next line of the body: Next line of the body: Next lin
e of the body: Next line of the body: Next line of the body: Next line of the
body: Next line of the body: Next line of the body: Next line of the body: N
ext line of the body: Next line of the body: Next line of the body: Next line
of the body: Next line of the body: Next line of the body: Next line of the
body: Next line of the body: Next line of the body: Next line of the body: Ne
xt line of the body: Next line of the body: Next line of the body: Next line
of the body: Next line of the body: Next line of the body: Next line of the b
ody: Next line of the body: Next line of the body: Next line of the body: Nex
t line of the body: Next line of the body: Next line of the body: Next line o
f the body: Next line of the body: Next line of the body: Next line of the bo
dy:
Next line of the body: END
set:phishing> Send email to: servando.lopez@upslp.edu.mx

1. Use a gmail Account for your email attack.
2. Use your own server or open relay

set:phishing>2
set:phishing> From address (ex: moo@example.com): y4uny4un@gmail.com
set:phishing> The FROM NAME the user will see: Equipo de Microsoft
set:phishing> Username for open-relay [blank]: a97304001@smtp-brevo.com
Password for open-relay [blank]:
set:phishing> SMTP email server address (ex. smtp.youremailserveryouown.com):
smtp-relay.brevo.com
set:phishing> Port number for the SMTP server [25]: 587
set:phishing> Flag this message/s as high priority? [yes/no]: y
Do you want to attach a file - [y/n]: n
Do you want to attach an inline file - [y/n]: n
[*] SET has finished sending the emails

Press <return> to continue
```

5. Fase 3: Ejecución y Resultados

Una vez procesados los datos, la herramienta confirmó el envío exitoso. En la fase de post-ejecución, se verificó la recepción del correo en la cuenta objetivo.

Ejemplo de recepción:

T

Tu OneDrive está a punto de eliminarse<y4uny4un@11105028.brevosend.com>

Para: Christopher Leonardo Bustamante Rocha

Lun 27/04/2026 12:43 PM

! **Importancia alta**

Parte del contenido de este mensaje fue bloqueado porque el remitente no está en la lista de remitentes seguros.

Remitente de confianza

Mostrar contenido bloqueado



[Reactivar tu cuenta](#) | [Ver en el navegador](#)

 Logotipo de Microsoft

Tu almacenamiento en la nube está inactivo y se eliminará pronto

 GIF de una nube con una X en ella

Tu servando.lopez@upslp.edu.mx cuenta lleva tiempo inactiva y actualmente está congelada. Tus archivos siguen ahí, pero tu almacenamiento en la nube y todos los archivos guardados en esa cuenta se eliminarán el o después del en esa cuenta se eliminarán el o después del **4/28/2026 10:26:21 AM**, a menos que [inicies sesión en OneDrive](#) y vuelvas a activarla.

Obtén más información sobre [lo que significa una cuenta congelada](#).

[Obtener más almacenamiento](#)

Activar Windows

Ve a Configuración para activar Windows.

Nota: Este mensaje se aplica solo a tu cuenta personal de almacenamiento en la nube. Este

T

Tu OneDrive está a punto de eliminarse<y4uny4un@11105028.brevosend.com>

Para: Christopher Leonardo Bustamante Rocha

Lun 27/04/2026 12:43 PM

! **Importancia alta**

[Reactivar tu cuenta](#) | [Ver en el navegador](#)

 Microsoft

Tu almacenamiento en la nube está inactivo y se eliminará pronto



Tu servando.lopez@upslp.edu.mx cuenta lleva tiempo inactiva y actualmente está congelada. Tus archivos siguen ahí, pero tu almacenamiento en la nube y todos los archivos guardados en esa cuenta se eliminarán el o después del en esa cuenta se eliminarán el o después del **4/28/2026 10:26:21 AM**, a menos que [inicies sesión en OneDrive](#) y vuelvas a activarla.

Obtén más información sobre [lo que significa una cuenta congelada](#).

[Obtener más almacenamiento](#)

Activar Windows

Ve a Configuración para activar Windows.

Reflexión

La práctica permitió observar de manera práctica el funcionamiento de SET como herramienta de auditoría de ingeniería social. Los resultados confirman dos aspectos fundamentales en el análisis de seguridad de correo electrónico:

En primer lugar, la facilidad con la que una herramienta automatizada puede configurar y enviar un correo con remitente falsificado ilustra por qué la concientización del usuario final sigue siendo la primera línea de defensa. Un usuario no capacitado podría abrir el mensaje basándose únicamente en el nombre del remitente visible, sin revisar las cabeceras.

En segundo lugar, los controles técnicos como SPF, DKIM y DMARC, cuando están correctamente implementados, son altamente efectivos para detectar y filtrar este tipo de mensajes antes de que lleguen al usuario. La ausencia de estos registros en el servidor de prueba resultó en el marcado automático como spam, lo cual demuestra su eficacia real.

Un punto crítico observado durante la práctica fue la dualidad entre la facilidad de ejecución y la sofisticación del rastro dejado. Aunque el uso de **SET** simplifica la creación del vector, la efectividad del ataque depende enteramente de la **ofuscación**. En entornos corporativos reales, la detección de este tipo de actividades no solo depende de herramientas como SPF o DKIM, sino del monitoreo de comportamientos anómalos en la red, como peticiones POST hacia direcciones IP externas inusuales o la resolución de nombres de dominio sospechosos.

Desde la perspectiva del equipo de defensa, este ejercicio aporta valor para comprender qué señales buscar en los logs de correo y cómo configurar alertas en un SIEM ante intentos de spear-phishing contra la organización.

Conclusión

Tras la finalización de la práctica y el análisis de los resultados obtenidos, se presentan las siguientes conclusiones:

1. **Vulnerabilidad del Factor Humano:** Se ratifica que la ingeniería social sigue siendo el vector más crítico. La capacidad de clonar sitios web de forma idéntica anula gran parte de la desconfianza visual del usuario, dejando la seguridad supeditada a la capacidad del individuo para verificar elementos técnicos como la URL o el certificado SSL.
2. **Eficacia de las Herramientas de Auditoría:** El **Social-Engineer Toolkit (SET)** demuestra ser una herramienta sumamente potente para equipos de *Red Team*. Su capacidad para integrar vectores de correo (SMTP) con vectores web (HTTP)

permite simular campañas de phishing complejas que exponen debilidades tanto en la configuración de servidores de correo como en la cultura de seguridad de la organización.

3. **Importancia de los Protocolos de Autenticación:** El ejercicio evidenció que la falta de firmas digitales y registros de validación (SPF/DMARC) facilita la suplantación. No obstante, se concluye que la implementación de **Autenticación de Múltiples Factores (MFA)** es la única medida definitiva capaz de mitigar el impacto de una recolección exitosa de credenciales.
4. **Resiliencia en el Flujo de Ataque:** La capacidad de adaptar el ataque a las restricciones del entorno (cambio de puertos y uso de diferentes entornos de ejecución como el intérprete manual o IDEs) demuestra que una auditoría de seguridad debe considerar no solo los ataques estándar, sino la creatividad del atacante para utilizar herramientas legítimas del sistema con fines maliciosos (técnicas *Living off the Land*).